

Semana 7 — Objetivos de Aprendizado

Anotações para a prova do dia 18

Entendendo Vulnerabilidades:

O que é uma vulnerabilidade de segurança cibernética?

Uma fraqueza ou falha em um sistema, processo ou design que pode ser explorada para comprometer a segurança.

Quais são os diferentes tipos de vulnerabilidades (software, hardware, rede)?

Bugs de software/falhas de implementação, fraquezas físicas/de firmware de hardware, e protocolos ou serviços de rede mal configurados, além do fator humano.

Como as vulnerabilidades levam a violações de segurança em organizações orientadas por tecnologia?

Atacantes identificam e exploram fraquezas para obter acesso não autorizado, exfiltrar dados ou interromper operações.

Qual é a diferença entre vulnerabilidades, ameaças e riscos?

Uma vulnerabilidade é uma fraqueza, uma ameaça é um atacante ou evento potencial que a explora, e o risco é a probabilidade/consequência dessa exploração.

O que são Common Vulnerabilities and Exposures (CVE)?

Um banco de dados padronizado de vulnerabilidades de segurança publicamente conhecidas com identificadores únicos para rastreamento e comunicação consistentes.

O que é gerenciamento de vulnerabilidades?

O processo contínuo de identificar, avaliar, priorizar, remediar e monitorar vulnerabilidades de segurança em uma organização.

O que é divulgação responsável no contexto de vulnerabilidades?

Reportar vulnerabilidades encontradas privadamente aos fornecedores primeiro, permitindo tempo para correções antes da divulgação pública.

Quais são as ferramentas comuns usadas para varredura de vulnerabilidades?

Nessus, OpenVAS, Qualys, Burp Suite, Nmap e Microsoft Baseline Security Analyzer.

Por que o gerenciamento de vulnerabilidades é essencial para a postura de segurança cibernética de uma empresa?

Ele reduz proativamente a superfície de ataque ao abordar sistematicamente as fraquezas antes que adversários possam explorá-las.

CVE, CWE e NVD:

O que são CVEs (Common Vulnerabilities and Exposures) e como eles ajudam na identificação e compartilhamento de informações sobre vulnerabilidades de segurança cibernética publicamente conhecidas?

CVEs são identificadores padronizados para vulnerabilidades de segurança publicamente conhecidas que permitem rastreamento, comunicação e referência consistentes em toda a comunidade global de segurança cibernética.

Qual é a estrutura de um identificador CVE (ex: CVE-2024-1234) e qual é o significado de cada parte?

O formato é composto por: prefixo "CVE", ano de descoberta/atribuição (2024) e número de ID sequencial (1234) dentro da emissão daquele ano.

Qual é o papel das CVE Numbering Authorities (CNAs) no processo de atribuição de CVE e quais são os critérios para se tornar uma CNA?

CNAs são organizações confiáveis autorizadas a atribuir IDs de CVE; elas devem demonstrar expertise no tratamento de vulnerabilidades e concordar em seguir as políticas e procedimentos da MITRE.

Como as vulnerabilidades são reportadas, revisadas e recebem um identificador CVE por meio do processo de registro CVE?

Os relatores submetem as descobertas às CNAs relevantes ou diretamente à MITRE, que revisa a validade, unicidade e prontidão para divulgação pública antes de emitir as atribuições de CVE.

Como você pode usar o banco de dados CVE para pesquisar e recuperar informações sobre vulnerabilidades específicas?

Use cve.mitre.org com filtros de busca por palavra-chave/CVE-ID por ano, produto, fornecedor ou classificações de severidade para buscas direcionadas.

O que são CWEs (Common Weakness Enumeration) e como eles ajudam na identificação de fraquezas comuns de software que podem levar a vulnerabilidades?

CWEs catalogam falhas de design/código de software que podem se tornar vulnerabilidades exploráveis, fornecendo uma taxonomia para desenvolvimento e testes seguros.

Quais são as diferentes categorias, tipos e estruturas hierárquicas dos CWEs?

Organizados como hierarquia em árvore a partir de fraquezas raiz (como CWE-79 XSS) por meio de subclasses que mostram instâncias específicas e relações entre tipos de fraquezas.

Como os CWEs estão relacionados aos CVEs e como eles descrevem os tipos de fraquezas que levam a vulnerabilidades?

Múltiplas entradas CVE frequentemente se mapeiam de volta a um único CWE — o CWE descreve o tipo de falha de causa raiz enquanto o CVE documenta manifestações de instâncias específicas.

Quais são algumas técnicas comuns de mitigação e boas práticas para tratar fraquezas identificadas por CWEs?

Validação de input, codificação de output, consultas parametrizadas, gerenciamento adequado de memória, revisão de código, ferramentas de análise estática e treinamento em codificação segura.

Como as fraquezas podem ser priorizadas com base em sua severidade, explorabilidade e impacto potencial usando a pontuação CWE?

O CWE em si não possui pontuação intrínseca, mas as equipes priorizam com base na probabilidade de exploit, criticidade do ativo, patches disponíveis e pontuações CVSS dos CVEs associados quando mapeados.

Qual é o papel do NVD (National Vulnerability Database) no ecossistema de segurança cibernética e como ele apoia o gerenciamento de vulnerabilidades?

O NVD serve como repositório mantido pelo governo dos EUA que agrega dados de CVE com detalhes enriquecidos como pontuações CVSS, configurações afetadas e orientações de remediação.

Que tipos de feeds de dados são fornecidos pelo NVD, incluindo métricas de vulnerabilidades, configurações e pontuações de impacto?

Feeds JSON/XML contendo detalhes de CVE, pontuações CVSS v2/v3, configurações CPE, produtos afetados, referências e atualizações de status de disponibilidade de patches.

Como você pode usar o CVSS (Common Vulnerability Scoring System) para avaliar a severidade das vulnerabilidades listadas no NVD?

O CVSS fornece métricas base/temporais/ambientais (vetor de ataque, complexidade, privilégios necessários, impacto) gerando pontuações numéricas de 0.0 a 10.0 para classificação de severidade.

Como você pode pesquisar, filtrar e recuperar informações de vulnerabilidades do NVD de forma eficaz?

Aplique filtros em nvd.nist.gov por CVE-ID, palavras-chave, intervalos de datas de publicação, limites de pontuação CVSS, nomes de produtos CPE ou combinações de fornecedor/plataforma.

Como os dados do NVD podem ser integrados com ferramentas e plataformas de segurança para gerenciamento automatizado de vulnerabilidades?

Extraia feeds de API para SIEMs, scanners, sistemas de ticketing e plataformas SOAR para correlacionar automaticamente descobertas com dados de vulnerabilidades conhecidas para fluxos de trabalho de priorização.

Vulnerabilidades de Upload

O que é upload irrestrito de arquivos?

É uma vulnerabilidade web onde uma aplicação aceita arquivos enviados sem validar adequadamente seu conteúdo, tipo ou estrutura.

Por que uploads de arquivos representam um risco de segurança?

Eles permitem que atacantes contornem os controles da aplicação ao fazer upload de código malicioso que o servidor pode executar, levando ao comprometimento total do sistema.

Como formulários de upload de arquivos podem ser explorados?

Atacantes enganam servidores para armazenar e executar malware, web shells ou scripts ao falsificar cabeçalhos, contornar verificações do cliente ou explorar fraquezas de extensão.

O que é um web shell?

Um web shell é um script malicioso enviado para um servidor que fornece aos atacantes uma interface de linha de comando remota para controlar o sistema comprometido.

Como os tipos MIME se relacionam com a segurança de uploads?

Tipos MIME indicam formatos de arquivo em cabeçalhos HTTP, mas depender exclusivamente deles é inseguro porque podem ser facilmente falsificados por atacantes.

O que é spoofing de Content-Type?

É a técnica de manipular o cabeçalho Content-Type em uma requisição de upload para fazer um arquivo malicioso parecer uma imagem ou documento seguro.

Como a validação server-side pode mitigar riscos?

A validação server-side impõe verificações rigorosas sobre magic numbers de arquivos, extensões e conteúdo antes do armazenamento, prevenindo efetivamente a execução de payloads não autorizados.

Qual é a importância da filtragem de extensões de arquivo?

Criar uma whitelist de extensões permitidas garante que apenas tipos de arquivo esperados (como .jpg) possam ser salvos, bloqueando scripts executáveis (como .php ou .exe).

Como as verificações client-side podem ser contornadas?

Validações client-side são executadas no navegador do usuário e podem ser facilmente contornadas modificando requisições com ferramentas de proxy como Burp Suite ou curl.

Quais são algumas boas práticas para upload seguro de arquivos?

As boas práticas incluem criar whitelist de extensões, verificar magic numbers de arquivos, renomear arquivos no upload, armazená-los fora do web root e desabilitar a execução de scripts em pastas de upload.

Como a limitação de tamanho de arquivo ajuda na segurança?

Limitar o tamanho dos arquivos previne ataques de negação de serviço causados por uploads massivos que encham o espaço em disco e desacelera tentativas de força bruta para fazer upload de payloads grandes.

Quais são os riscos de armazenar arquivos no mesmo domínio?

Armazenar uploads no mesmo domínio permite que scripts maliciosos potencialmente acessem cookies, armazenamento local ou realizem bypasses de Same Origin Policy contra seu site legítimo.

Como as permissões de arquivo afetam a segurança de uploads?

Permissões inadequadas (como 777) em diretórios de upload concedem direitos não intencionais de leitura/escrita/execução, permitindo que atacantes modifiquem ou executem os arquivos maliciosos que colocaram lá.

Por que os diretórios de upload não devem ser executáveis?

Desabilitar permissões de execução garante que, mesmo que um script malicioso seja enviado com sucesso, o servidor web o trate como dados em vez de executá-lo como código.